Cyber Security

Module 4: Cyber Attacks

Exam-Oriented Study Notes

BCA, MAKAUT

Contents

1 Cyber Attacks **3**
1.1 Basic Terms . . . 3
1.2 Motives of Attackers . . . 3
1.3 Stages of a Typical Attack (Cyber Kill Chain) . . . 3
1.4 Classification of Attacks . . . 3
1.5 Cyber Crime Laws in India . . . 3

2 Types of Attacks: Passive and Active **4**
2.1 Passive Attacks . . . 4
2.2 Active Attacks . . . 4
2.3 Comparison . . . 5

3 Malware **5**
3.1 Types of Malware . . . 5
3.2 Virus vs Worm vs Trojan . . . 6
3.3 Infection Methods . . . 6
3.4 Signs of Infection . . . 6
3.5 Prevention . . . 6

4 Phishing **6**
4.1 How Phishing Works . . . 6
4.2 Types of Phishing . . . 7
4.3 Red Flags . . . 7
4.4 Prevention . . . 7

5 Denial of Service (DoS) **7**
5.1 DoS vs DDoS . . . 8
5.2 DDoS Structure (Botnet) . . . 8
5.3 Types of DoS/DDoS Attacks . . . 8
5.4 Effects . . . 8
5.5 Prevention and Mitigation . . . 8

6 SQL Injection **9**
6.1 How It Works (Example) . . . 9
6.2 Types of SQL Injection . . . 9
6.3 Impact . . . 9
6.4 Prevention . . . 9

7 Social Engineering **10**
7.1 Psychological Principles Used . . . 10
7.2 Common Techniques . . . 10
7.3 Life Cycle . . . 10
7.4 Defences . . . 10

8 Insider Threats **11**
8.1 Types of Insiders . . . 11
8.2 Why Insiders Are Dangerous . . . 11
8.3 Warning Signs . . . 11
8.4 Mitigation . . . 11

9 Case Studies of Major Cyber Attacks **12**
9.1 Overview Table 12
9.2 Other Notable Incidents (Short Notes) 13
9.3 Common Lessons from All Cases 14

10 Quick Revision Sheet **15**

1 Cyber Attacks

Definition

A **cyber attack** is a deliberate attempt by an individual or group to gain unauthorised access to, damage, steal from, or disrupt a computer system, network or data. It targets one or more of the **CIA** goals: confidentiality, integrity and availability.

1.1 Basic Terms

Term	Meaning
Attacker (threat actor)	Person or group carrying out the attack
Attack vector	Path or method used to reach the target (email, USB, open port, web form)
Attack surface	Total set of points where an attacker can try to enter
Payload	The harmful part that executes after entry (e.g. ransomware code)
Zero-day	Attack on a vulnerability that the vendor does not yet know or has not patched
Exploit	Code or technique that uses a vulnerability

1.2 Motives of Attackers

Financial gain, espionage (state or corporate), hacktivism (cause), revenge by insiders, disruption or cyber warfare, and fun or reputation.

1.3 Stages of a Typical Attack (Cyber Kill Chain)

1. **Reconnaissance:** gather information about the target.
2. **Weaponisation:** prepare the malware or exploit.
3. **Delivery:** send it (email, website, USB).
4. **Exploitation:** trigger the vulnerability.
5. **Installation:** install malware or a backdoor.
6. **Command and Control (C2):** attacker gains remote control.
7. **Actions on objectives:** steal, encrypt, destroy or disrupt.

1.4 Classification of Attacks

- **By nature:** passive and active attacks (Section 2).
- **By source: external** (outsiders) and **internal** (insiders).
- **By target:** network, system, application, human (social engineering).

1.5 Cyber Crime Laws in India

The **Information Technology Act, 2000** covers cyber offences, for example: **Section 43** (unauthorised access or damage), **Section 66** (computer-related offences, including hacking), **66C** (identity theft), **66D** (cheating by personation using a computer) and **66F** (cyber terrorism).

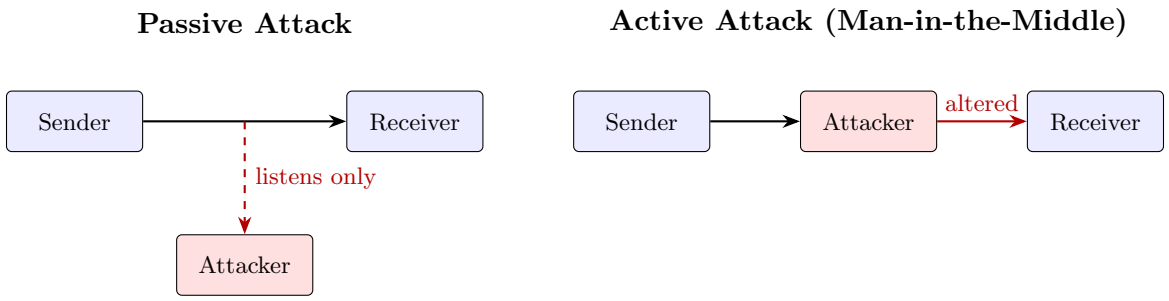
Exam Tip

When asked for "cyber attacks", first define it, state the **CIA goal** each attack targets, and then classify (passive/active, internal/external). The kill chain gives a neat step-wise answer.

Practice Questions

Short Answer: (1) Define cyber attack. (2) What is a zero-day attack? (3) Differentiate attack vector and attack surface.
Long Answer: (4) Explain the stages of a cyber attack with a suitable example.

2 Types of Attacks: Passive and Active



2.1 Passive Attacks

Definition

In a **passive attack** the attacker only **observes or monitors** communication or data and does not change it. It is hard to detect because nothing is modified. It threatens **confidentiality**.

- **Eavesdropping / sniffing:** capturing packets on a network (e.g. on open Wi-Fi) with tools such as Wireshark.
- **Release of message contents:** reading sensitive emails or files.
- **Traffic analysis:** even if messages are encrypted, studying who talks to whom, how often and how much, to learn patterns.

Defence: prevention rather than detection, mainly **encryption** (TLS, VPN, WPA3).

2.2 Active Attacks

Definition

In an **active attack** the attacker **modifies, creates, replays or blocks** data or services. It is easier to detect but causes direct damage. It threatens **integrity, availability and authenticity**.

- **Masquerade (spoofing):** pretending to be another user, device or IP/MAC address.
- **Replay:** capturing a valid message and resending it later (e.g. a login or payment request).
- **Modification of messages:** altering content in transit (man-in-the-middle).
- **Session hijacking:** taking over a valid session by stealing the session ID.
- **Denial of Service:** making a service unavailable (Section 5).

Defence: detection and recovery: authentication, digital signatures, timestamps and nonces (against replay), IDS/IPS, firewalls.

2.3 Comparison

Basis	Passive Attack	Active Attack
Action	Only monitors or reads	Modifies, injects, replays or blocks
Effect on data	None	Data or system is altered or disrupted
Goal affected	Confidentiality	Integrity, availability, authenticity
Detection	Very difficult	Easier to detect
Main defence	Prevention (encryption)	Detection and recovery
Examples	Sniffing, traffic analysis	MITM, replay, spoofing, DoS

Exam Tip

"Differentiate passive and active attacks" is a frequent 5-mark question. Draw both diagrams, then write **at least five points** in table form with examples.

Practice Questions

Short Answer: (1) Why are passive attacks hard to detect? (2) What is a replay attack? (3) Give two examples each of passive and active attacks.

Long Answer: (4) Compare passive and active attacks with diagrams.

3 Malware

Definition

Malware (malicious software) is any program or code designed to harm, exploit, spy on or gain unauthorised access to a computer, network or user.

3.1 Types of Malware

Type	Description	Example
Virus	Attaches itself to a host file or program; spreads when the infected file is run or shared	CIH, Melissa
Worm	Self-replicating; spreads over networks **without user action**	Morris, ILOVEYOU
Trojan Horse	Looks like useful software but hides malicious code; does not self-replicate	Zeus (banking trojan)
Ransomware	Encrypts files and demands payment for the key	WannaCry, NotPetya
Spyware	Secretly collects user information	Pegasus (mobile spyware)
Keylogger	Records keystrokes to steal passwords and card details	Hardware or software loggers
Adware	Shows unwanted advertisements, may track users	Bundled free software
Rootkit	Hides malware and gives privileged, hidden access	Sony BMG rootkit
Backdoor	Secret way to bypass normal authentication	Remote access trojans
Botnet / Bot	Infected device controlled remotely, part of a network of bots	Mirai
Logic bomb	Code that triggers on a condition (date, event)	Insider sabotage
Fileless malware	Runs in memory using legitimate tools, leaves few traces	PowerShell-based attacks

3.2 Virus vs Worm vs Trojan

Basis	Virus	Worm	Trojan
Needs host file	Yes	No (standalone)	No (disguised program)
Replication	Yes, by infecting files	Yes, by itself over network	No
User action needed	Usually yes	No	Yes (user installs it)
Main aim	Corrupt files, spread	Consume bandwidth, spread fast	Steal data, open backdoor

3.3 Infection Methods

Email attachments and links, malicious or cracked software downloads, infected USB drives, drive-by downloads from compromised websites, unpatched vulnerabilities, and malicious mobile apps.

3.4 Signs of Infection

Slow system, unexpected pop-ups, unknown programs or processes, files renamed or encrypted, disabled antivirus, high network use, and unusual account activity.

3.5 Prevention

Install and update antivirus/EDR, apply patches, avoid pirated software, do not open unknown attachments, limit admin rights, use application whitelisting, and keep **offline backups** (the best defence against ransomware).

Exam Tip

The virus–worm–trojan comparison is the classic question. Remember: **virus needs a host, worm spreads alone, trojan pretends to be useful**.

Practice Questions

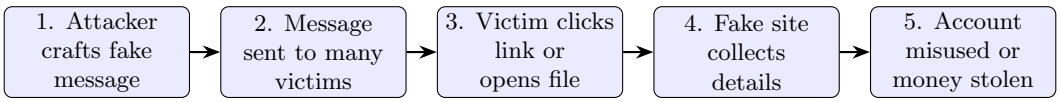
Short Answer: (1) Define malware. (2) What is ransomware? (3) Differentiate worm and virus.
Long Answer: (4) Explain the different types of malware with examples. (5) How can a user protect a system from malware?

4 Phishing

Definition

Phishing is a social-engineering attack in which the attacker pretends to be a trusted organisation or person (bank, courier, employer) and tricks the victim into revealing **sensitive information** (passwords, OTP, card details) or installing malware, using fake emails, messages, calls or websites.

4.1 How Phishing Works



4.2 Types of Phishing

Type	Description
Email phishing	Mass fake emails to a large number of people
Spear phishing	Targeted at a specific person or organisation, using personal details
Whaling	Spear phishing aimed at senior executives (CEO, CFO)
Smishing	Phishing through SMS (fake KYC or parcel messages)
Vishing	Voice phishing through phone calls (fake bank officer)
Clone phishing	Copy of a genuine earlier email with a malicious link or file
Pharming	Redirecting users to a fake website by poisoning DNS or the hosts file
Business Email Compromise (BEC)	Impersonating a boss or vendor to request urgent payments

4.3 Red Flags

- Urgent or threatening language ("account will be blocked").
- Sender address or URL slightly different from the real one.
- Requests for passwords, OTP, PIN or card details (a bank never asks for these).
- Generic greeting, spelling errors, unexpected attachments.
- Links where the hover address does not match the shown text.

4.4 Prevention

Verify the sender through another channel, never share OTP or PIN, type the website address yourself, enable **multi-factor authentication**, use spam filters and email authentication (SPF, DKIM, DMARC), keep browsers updated, run phishing awareness training, and report suspicious messages (in India, cyber crime can be reported on the national cyber crime portal or helpline 1930).

Exam Tip

List at least four types (spear, whaling, smishing, vishing) with one-line explanations and finish with prevention points. A flow diagram of the five steps adds marks.

Practice Questions

Short Answer: (1) Define phishing. (2) Differentiate spear phishing and whaling. (3) What is pharming?
Long Answer: (4) Explain phishing, its types, warning signs and prevention methods.

5 Denial of Service (DoS)

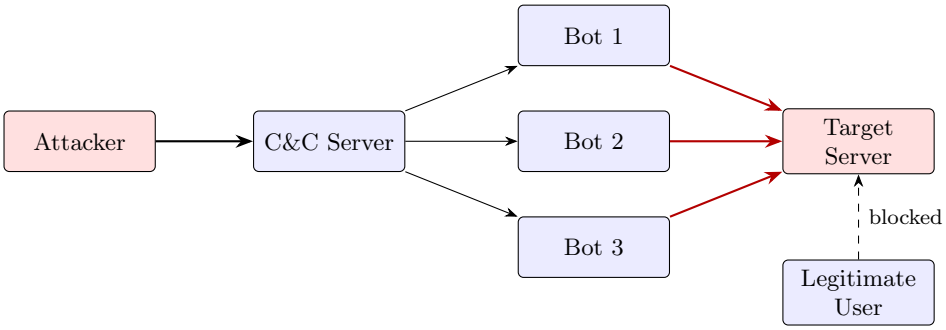
Definition

A **Denial of Service (DoS)** attack floods or crashes a system, network or service so that **legitimate users cannot access it**. When the attack comes from **many compromised machines** at once it is a **Distributed DoS (DDoS)**. It targets **availability**.

5.1 DoS vs DDoS

Basis	DoS	DDoS
Source	Single machine or connection	Thousands of machines (botnet)
Scale	Limited	Very large
Detection and blocking	Easy (block one IP)	Hard (traffic from many IPs)
Traceability	Easier to trace	Difficult to trace the real attacker

5.2 DDoS Structure (Botnet)



5.3 Types of DoS/DDoS Attacks

Category	How it Works	Examples
Volumetric	Consumes all bandwidth with huge traffic	UDP flood, ICMP (ping) flood, DNS amplification
Protocol attacks	Exhaust server or firewall resources by abusing protocols	SYN flood, ping of death, Smurf
Application layer	Overloads a web application with seemingly legitimate requests	HTTP flood, Slowloris

SYN flood: the attacker sends many SYN requests and never completes the three-way handshake, filling the server's half-open connection table (see Module 1).

5.4 Effects

Website or service downtime, financial loss, damaged reputation, and sometimes a **smokescreen** used to distract defenders during another attack.

5.5 Prevention and Mitigation

- **Rate limiting** and connection limits; SYN cookies.
- **Firewalls, IPS and filtering** of spoofed or malicious traffic.
- **CDN and DDoS-protection (scrubbing) services**; extra bandwidth; load balancers.
- **Redundancy:** multiple servers and data centres.
- **Blackhole routing** as a last resort, and an **incident response plan**.
- Securing devices so they do not become bots (change default passwords, patch).

Exam Tip

Always mention that DoS attacks **availability**, draw the botnet diagram for DDoS, and give one example per type (SYN flood, UDP flood, HTTP flood).

Practice Questions

Short Answer: (1) Define DoS. (2) What is a botnet? (3) Which CIA goal does DDoS affect?
Long Answer: (4) Explain DoS and DDoS attacks, their types and prevention with a diagram.

6 SQL Injection

Definition

SQL Injection (SQLi) is a web application attack in which an attacker inserts **malicious SQL code** through an input field (login form, search box, URL parameter) so that the application's database runs unintended commands. It happens when user input is placed **directly** into a query without proper checks.

6.1 How It Works (Example)

A vulnerable login builds its query by joining text:

```
SELECT * FROM users WHERE name = '$name' AND pass = '$pass';
```

If the attacker types `admin' --` as the name, the single quote closes the text value and `--` turns the rest of the line into a comment:

```
SELECT * FROM users WHERE name = 'admin' -- ' AND pass = '';
```

The password check is ignored, so the attacker logs in as `admin` without a password. The same idea can be used to read, change or delete data.

6.2 Types of SQL Injection

Type	Description
In-band (classic)	Result is seen directly in the same channel; includes error-based and UNION-based
Blind (inferential)	No data shown; attacker infers from true/false responses or time delays
Out-of-band	Data is sent to the attacker through a different channel (e.g. DNS or HTTP request)

6.3 Impact

Authentication bypass, theft of sensitive data (customer records, passwords), modification or deletion of data, and in severe cases control of the database server. It affects **confidentiality, integrity and availability**.

6.4 Prevention

- **Parameterised queries (prepared statements):** the best defence; input is treated only as data, never as code.
- **Input validation and sanitisation:** allow-list expected characters and length.
- **Least privilege:** database accounts should have only the permissions they need.
- **Hide error messages** from users; log them privately.
- **Web Application Firewall (WAF)**, regular code review and security testing, and storing passwords as salted hashes.

Remember

SQLi is ranked among the most serious web risks (OWASP "Injection" category). The root cause is **mixing code and data**; prepared statements keep them separate.

Exam Tip

Write the vulnerable query, the malicious input and the resulting query, then list the prevention points. Emphasise **prepared statements**.

Practice Questions

Short Answer: (1) What is SQL injection? (2) What is blind SQL injection? (3) Name the best defence against SQLi.
Long Answer: (4) Explain SQL injection with an example, its types and prevention.

7 Social Engineering

Definition

Social engineering is the art of **manipulating people** into giving away confidential information or performing actions that compromise security. It attacks the **human factor**, often called the weakest link, instead of technology.

7.1 Psychological Principles Used

Authority (pretending to be a boss or officer), urgency and fear, trust and familiarity, greed or curiosity, helpfulness, reciprocity ("I did you a favour"), and social proof.

7.2 Common Techniques

Technique	Description
Pretexting	Inventing a believable story or identity (IT support, auditor) to obtain information
Baiting	Leaving tempting bait, such as an infected USB drive labelled "Salary"
Tailgating / Piggybacking	Following an authorised person through a secured door
Quid pro quo	Offering a service or reward in exchange for information ("free tech support")
Shoulder surfing	Watching someone enter a PIN or password
Dumpster diving	Searching rubbish for documents, notes or devices
Impersonation	Posing as an employee, courier or technician
Phishing, vishing, smishing	Digital and phone-based forms (Section 4)

7.3 Life Cycle

Research the target → **build trust** → **exploit** the trust to get information or access → **exit** without leaving suspicion.

7.4 Defences

- Regular **security awareness training** and simulated phishing tests.
- Verify identities independently (call back on a known number).

- Clear policies: never share passwords or OTP; escort visitors; use ID badges and access cards.
- Shred documents, lock screens, and disable unknown USB use.
- Encourage a culture where staff can **report suspicious activity** without blame.

Exam Tip

Link social engineering to **human psychology**: always say technical controls alone cannot stop it. Give at least four techniques with a real-life example each.

Practice Questions

Short Answer: (1) Define social engineering. (2) What is tailgating? (3) Give an example of baiting.
Long Answer: (4) Explain social engineering attacks, techniques and countermeasures.

8 Insider Threats

Definition

An **insider threat** is a security risk that comes from **people inside the organisation**, such as employees, contractors or partners, who have legitimate access to systems and data and misuse it, intentionally or by mistake.

8.1 Types of Insiders

Type	Description	Example
Malicious insider	Deliberately steals or damages for money, revenge or espionage	Employee selling customer data
Negligent insider	Careless or untrained; breaks rules by mistake	Clicking a phishing link, losing a laptop
Compromised insider	Account or device taken over by an outsider	Stolen employee credentials

8.2 Why Insiders Are Dangerous

They already have **legitimate access**, know where valuable data is and how controls work, and their activity looks normal, so detection takes longer.

8.3 Warning Signs

Accessing data unrelated to the job, working at odd hours, large downloads or copying to USB or personal email, attempts to bypass controls, disgruntlement or conflict, and resignation or notice period followed by unusual activity.

8.4 Mitigation

- **Least privilege** and **need-to-know** access; role-based access control.
- **Separation of duties** so that no single person controls a whole process.
- **Monitoring and logging**: DLP (Data Loss Prevention), UEBA (behaviour analytics), regular log review.
- **Background checks** before hiring and **NDAs**.

- **Prompt offboarding:** disable accounts and collect devices when someone leaves.
- Security awareness training and a clear acceptable use policy.

Exam Tip

Mention all **three types** (malicious, negligent, compromised). Many students only write about malicious insiders. Add least privilege and separation of duties as key controls.

Practice Questions

Short Answer: (1) Define insider threat. (2) Differentiate malicious and negligent insiders. (3) What is separation of duties?

Long Answer: (4) Explain insider threats, warning signs and ways to reduce them.

9 Case Studies of Major Cyber Attacks

9.1 Overview Table

Attack	Year	Type	Key Lesson
Morris Worm	1988	Worm	Led to the creation of CERT; showed the need for patching and strong passwords
Stuxnet	2010	Targeted worm	Malware can damage physical industrial systems
Target breach	2013	Supply-chain, malware	Third-party access must be controlled
Mirai / Dyn	2016	IoT botnet, DDoS	Default passwords on IoT devices are dangerous
Equifax	2017	Exploited unpatched flaw	Patch management is critical
WannaCry	2017	Ransomware worm	Unpatched systems and weak backups
SolarWinds	2020	Supply-chain	Trusted software updates can be abused
AIIMS Delhi	2022	Ransomware	Critical services need backups and segmentation

Case Study: WannaCry Ransomware (2017)

What happened: In May 2017 a ransomware worm spread across the world, infecting well over 200,000 computers in about 150 countries. It encrypted files and demanded Bitcoin. UK hospitals (NHS) were badly hit, with appointments and operations cancelled.
How it worked: It used the **EternalBlue** exploit against a flaw in the Windows **SMBv1** protocol, for which Microsoft had already released a patch (MS17-010). It then spread on its own to other vulnerable machines (worm behaviour). A researcher stopped the first wave by registering a hidden "kill-switch" domain. Several governments attributed it to a North Korea-linked group.
Attack types involved: malware (ransomware plus worm), active attack, availability violation.
Lessons: apply security patches quickly, retire old operating systems and protocols, segment networks, and keep tested offline backups.

Case Study: Target Data Breach (2013)

What happened: Attackers stole payment card data of roughly **40 million** customers, plus personal details of about 70 million, during the holiday season.
How it worked: The attackers first stole credentials from a **third-party HVAC contractor** (via a phishing-style attack) and used them to enter Target's network. They then moved inside and installed **point-of-sale (POS) malware** that captured card data from memory.
Attack types involved: phishing / social engineering, malware, supply-chain (third-party) attack.

Lessons: control and monitor vendor access, **segment** payment systems from other networks, and respond to security alerts quickly.

Case Study: Equifax Breach (2017)

What happened: The credit bureau Equifax exposed personal data of about **147 million** people, including names, dates of birth and identity numbers.
How it worked: The attackers exploited a known vulnerability in the **Apache Struts** web framework (CVE-2017-5638) that had a patch available but had not been applied to a public-facing system. They stayed inside for weeks.
Attack types involved: exploitation of unpatched software (active attack), data theft (confidentiality violation).
Lessons: strong **patch management**, asset inventory, network segmentation, and better monitoring to detect long-running intrusions.

Case Study: Mirai Botnet and the Dyn DDoS (2016)

What happened: In October 2016 a massive DDoS attack on the DNS provider **Dyn** made many popular websites (such as Twitter, Netflix and others) unreachable for many users, mainly in the US and Europe.
How it worked: The **Mirai** malware scanned the Internet for IoT devices (cameras, routers, DVRs) using **default usernames and passwords**, infected them, and formed a huge botnet that flooded Dyn with traffic.
Attack types involved: malware (botnet), DDoS (volumetric), availability violation.
Lessons: change default credentials, update IoT firmware, and use DDoS protection and redundant DNS.

Case Study: SolarWinds Supply-Chain Attack (2020)

What happened: Attackers secretly inserted malicious code into software updates of the **SolarWinds Orion** network-management product. Thousands of customers, including government agencies and large companies, installed the infected update, and the attackers selectively spied on high-value targets.
Attack types involved: supply-chain attack, backdoor malware, espionage (stealthy active attack).
Lessons: even **trusted updates** can be compromised, so use secure build pipelines, software integrity checks, least privilege, network monitoring and a zero-trust approach.

9.2 Other Notable Incidents (Short Notes)

- **Morris Worm (1988):** written by a student, it exploited a mail-server debug feature, a finger-service flaw and weak passwords, and slowed a significant share of the early Internet. It led to the formation of the first **CERT** and was the first major prosecution under US computer crime law.
- **Stuxnet (2010):** a highly sophisticated worm that used several zero-day flaws to target industrial controllers (Siemens PLCs) and damage Iranian uranium-enrichment centrifuges. It is widely believed to be state-created.
- **AIIMS Delhi (2022):** a ransomware attack on the hospital's servers disrupted online patient services for many days, forcing staff to work manually. It highlighted the need for backups, segmentation and incident response in healthcare.

9.3 Common Lessons from All Cases

Weakness	Defence
Unpatched software	Timely patch management
Weak or default passwords	Strong passwords, MFA, change defaults
Poor network design	Segmentation, least privilege
Third-party risk	Vendor assessment and restricted access
Human error	Awareness training
No tested backups	Offline backups and recovery drills
Late detection	Logging, monitoring, SIEM, incident response plan

Exam Tip

For case-study answers use this structure: *What happened* → *How it worked (attack type)* → *Impact* → *Cause* → *Lessons*. Learn at least **three cases** well (WannaCry, Target, Equifax) and quote approximate numbers only.

Practice Questions

Short Answer: (1) What vulnerability did WannaCry exploit? (2) How was Target attacked through a third party? (3) What is a supply-chain attack?

Long Answer: (4) Discuss any two major cyber attacks, covering cause, impact and lessons learnt. (5) Explain how the Mirai botnet caused a large DDoS attack.

10 Quick Revision Sheet

Topic	Remember
Cyber attack	Deliberate attempt to breach or disrupt; targets C, I or A
Passive attack	Only observes (sniffing, traffic analysis); prevent with encryption
Active attack	Modifies or disrupts (MITM, replay, spoofing, DoS); detect and recover
Virus / Worm / Trojan	Needs host / spreads alone / disguised as useful
Ransomware defence	Offline backups, patching, user awareness
Phishing types	Spear, whaling, smishing, vishing, pharming, BEC
DoS vs DDoS	Single source vs botnet; both attack availability
DDoS types	Volumetric, protocol (SYN flood), application (HTTP flood)
SQL injection	Malicious SQL via input; fix with prepared statements
Social engineering	Manipulates people: pretexting, baiting, tailgating
Insider types	Malicious, negligent, compromised
Insider controls	Least privilege, separation of duties, DLP, offboarding
Case studies	WannaCry (patching), Target (vendor), Equifax (patching), Mirai (default passwords), SolarWinds (supply chain)